153

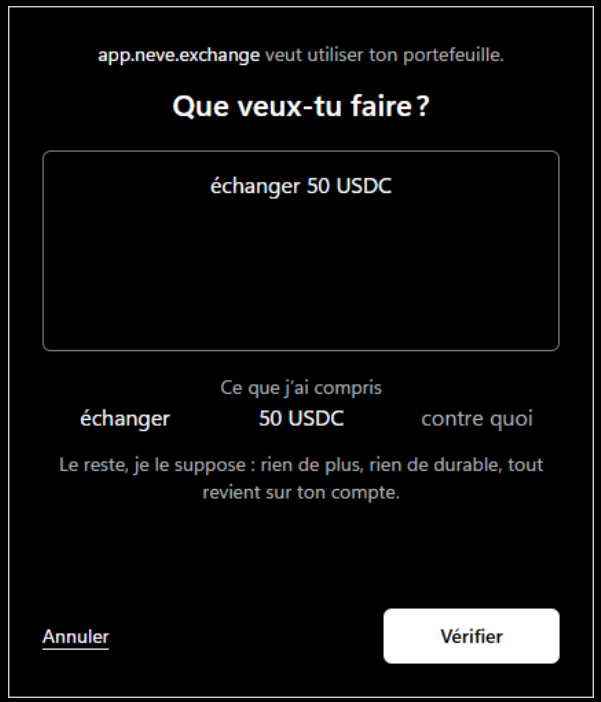
portefeuilles vidés chez LI.FI en juillet 2024 : 11,6 millions de dollars.

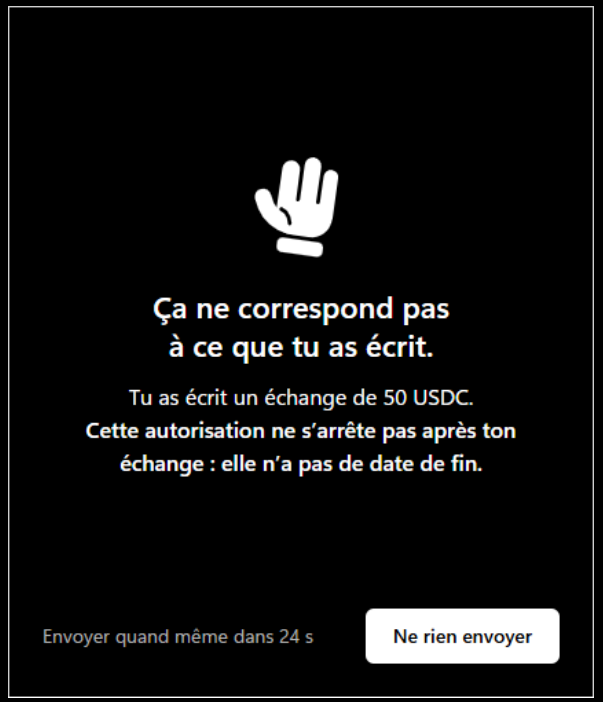
Tous avaient laissé une autorisation illimitée. Ceux qui l'avaient limitée n'ont rien perdu.

Sur Avalanche, une autorisation sur trois est illimitée.

Dans le dépôt : research/demo_reelle/RECHERCHE_douleurs_secondaires.md, research/titouan/Z_approbations/onchain/result_avax.json

Tu écris. Je compare. Tu décides.





Tu choisis.

Ne rien envoyer. Ou limiter l'autorisation à 50 USDC, puis envoyer.

Rien ne part tout seul.

Dans le dépôt : docs/design/system/planche.html (écrans du système de design, en cours d'intégration dans l'extension)

Tu échanges 50 USDC. Plus tard, le site est piraté.

1 Tu as 100 USDC. Tu en échanges 50 sur un site honnête.

2 Pour le faire, le site te demande l'accès à tout ton USDC, sans date de fin.

3 Plus tard, ce site est piraté. Il te restait 50 USDC.

Sans Hold up, il te reste

0 USDC

Le pirate se sert de l'accès illimité.

Avec Hold up, il te reste

50 USDC

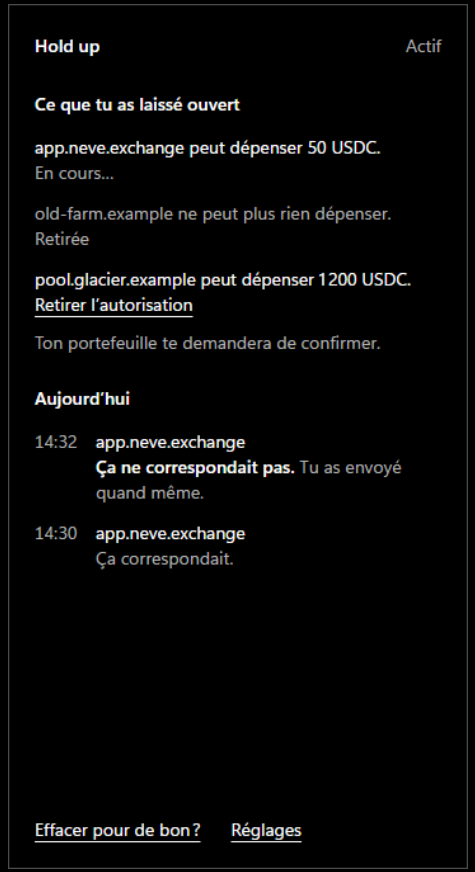
Tu avais limité l'accès aux 50 de l'échange. Il n'y a plus rien à prendre.

Dans le dépôt : research/demo_reelle/site_echange/test/preuve_piratage.mjs (chaîne locale, compte de test)

Une autorisation déjà donnée ? Tu la retires.

Je prépare le retrait. Ton portefeuille le signe. Hold up ne signe jamais.

Jamais joué devant un vrai portefeuille.



Dans le dépôt : research/titouan/T_banc_e2e/extension/revoke.js, tests/unit/revoke.test.mjs

Mesuré : l’extension, et le moteur de comparaison

L’extension

Réserve scellée, 2 673 paires, ouverte une fois.

75 %	des demandes non conformes attrapées (1 334 sur 1 789)
0	laissée passer sans alerte
25 %	« Je n’ai pas pu vérifier »
14 %	de fausses alertes (71 sur 515 demandes conformes)

Le moteur de comparaison

Jeu aveugle de 250 cas, écrits sans voir nos règles.

87 %	des arnaques signalées avec la phrase
65 %	sans la phrase
15 %	d’opérations honnêtes arrêtées à tort (seuil fixé avant : 10 %)

Extension mesurée sans modèle (mots-clés seuls), sur le build 6b9de2f d’avant le nouvel habillage, avec un fichier de décision modifié hors commit.

Dans le dépôt : preuves/RESULTAT_RESERVE_MOTS.md, research/titouan/T_banc_e2e/blind_decalage/run/RESULTAT.md

36 parcours. Notre testeuse s’est fait piéger 4 fois.

Les 4 fois, elle avait lu « Ça ne correspond pas » et appuyé sur « Continuer » quand même. Jamais piégée sans ce geste. La testeuse est un agent qui joue une personne prudente, au clavier.

Ce que Hold up ne fait pas encore

Je ne vérifie pas ce que tu reçois en échange.

Je ne couvre ni un Ledger en direct, ni le téléphone.



L’extension, pendant l’essai.

Dans le dépôt : coord/reports/testeurs/3_prudente_clavier.md, preuves/exhaustivite/EXHAUSTIVITE_INTENTION.md

On ne sait pas quel site sera piraté. On décide de ce qu'on lui laisse.

Dans le dépôt : research/titouan/BM2/BM_MODELE.md, BM_LABEL.md